

NIST AI RMF 1.0 mapping: what P1 and P3 actually do

Framework	NIST AI Risk Management Framework 1.0 (NIST AI 100-1, January 2023) [NIST-1], with the Generative AI Profile (NIST AI 600-1, July 2024) [NIST-2]
System	The Lumi Skin customer-service assistant (P1, shop-support-agent), evaluated by P1's own evals and by P3 (multilingual-llm-eval)
Date	8 October 2026; updated the same evening with P1's and P3's live results

The AI RMF is voluntary. NIST's page says that version 1.0 "is being revised" [NIST-1]; check it for a newer version before you reuse this mapping. This is not legal advice.

How to read this

The AI RMF has four functions:

- **Govern** sets the culture, the roles and the policies.
- **Map** sets the context and finds the risks.
- **Measure** analyses and tracks the risks.
- **Manage** prioritises the risks and acts on them.

For each subcategory we used, the table says **what the projects actually did** and where the proof is. It also marks what is **missing**. We did not tick a box because a document says it *should* happen.

Status key:

- **Done** means the artefact exists and, where it is a test or an evaluation, it ran and passed on 8 October 2026.
- **Pending** means the method exists but needs a live model run or a person's review.
- **Gap** means it does not exist yet.

The evidence IDs (E01...) are rows in [evals/evidence_index.csv](#).

GOVERN

Subcategory (short)	What P1 / P3 / P8 actually did	Proof	Status
GV-1.1 Legal and regulatory requirements are understood	EU AI Act memo (Art. 50 applies from 2 August 2026); UAE PDPL and DIFC Regulation 10 notes	03_eu_ai_act_memo.md , 05_uae_data_protection_notes.md	Done (counsel review: Gap)
GV-1.3 / 1.4 The level of risk management is set and documented	A 15-row risk register with a rating rule, a status rule and a validator in CI	risk_register.csv , <code>validate_register.py</code>	Done
GV-1.5 Ongoing monitoring and periodic review are planned	Change rule and review cadence in the runbook	runbook section 7	Done (process not yet exercised)
GV-1.6 AI systems are inventoried	A system card with the model roles, the exact OpenRouter model IDs and the run date	01_system_card.md	Done
GV-2.1 Roles and responsibilities are documented	Each risk has an owner role. The runbook defines approver, supervisor, on-call engineer and data protection	register owner column; runbook section 2	Done

	lead.		
GV-2.2 Personnel get AI risk training	An AI-literacy briefing for approvers is planned (EU AI Act Art. 4)	runbook launch checklist	Gap
GV-3.2 Roles for human-AI configuration and oversight are defined	A permission table: the agent queues; people decide; a supervisor decides above AED 200. Since the DR-2 fix the reviewer's role comes from configuration, not an on-screen choice.	P1 docs/architecture.md; tests [E05, E40]	Done (sign-in for approvers: Gap, DR-2 partly fixed)
GV-4.1 / 4.3 Safety-first culture; testing and incident sharing	Tests block the network and keys; "never invent metrics" is enforced by the validator; incident playbooks exist	P1 tests/conftest.py; [E32]	Done
GV-5.1 Feedback from people outside the team is collected	Customers can ask for a person at any time; handover tickets	P1 create_ticket; [E09]	Partly (no feedback analysis yet)
GV-6.1 / 6.2 Third-party (model and provider) risks have policies and contingencies	Models come through OpenRouter. If a model fails, a fixed template answer is used (probe and committed tests). Data-processing terms and an Article 50(2) marking question are open.	[E36, E38]; R11 and R14 in the register	Partly

MAP

Subcategory (short)	What was done	Proof	Status
MP-1.1 Intended purpose, users, context and laws are documented	Purpose, users and out-of-scope uses	system card sections 1-2	Done
MP-1.5 / 1.6 Risk tolerance and system requirements	Hard requirements written as code rules: verification, approval, AED 200, disclosure; the target is 0 violations in 120 conversations	P1 BUILD_SPEC.md, guards.py	Done
MP-2.1 The tasks and methods are defined	An 8-intent classifier plus a reply writer; tools chosen by code	P1 prompts.py, agent.py	Done
MP-2.2 Knowledge limits, and how humans use and oversee the output, are documented	What it can and cannot do; human approval	system card section 2	Done
MP-3.4 / 3.5 Operator proficiency and human-oversight processes are defined	An approver checklist and escalation path	runbook	Done (training: Gap)
MP-4.1 Risks from third-party components are mapped	Model provider outage, cross-border transfer, Article 50(2) marking	R11, R14; EU memo section 5.2	Done (mapped, not yet treated)
MP-5.1 The likelihood and size of impacts are characterised	Likelihood × impact for 15 risks	risk_register.csv	Done (judgement, not measured)

MEASURE

Subcategory (short)	What was done	Proof	Status
MS-1.1 Metrics are chosen for	P1's violation checks target the top risks: leaked_other_customer_data, order_lookup_without_verification,	P1 evals/scoring.py; P3 src/multieval/leak_checks.py	Done

the most significant risks first	change_applied_without_human, refund_over_200_not_escalated and missing_ai_disclosure. P3 adds red-team block rate and rule-based leak checks.		
MS-1.3 People other than the builders assess the system	A P8 design review and probes of P1 (re-run after P1's fixes). Sara grades P1 and P3 outputs as a native speaker.	06_red_team_findings.md [E34, E35, E36, E40]; [E19, E29]	Partly (the reviewer is the same coding agent family; Sara's grading is Pending)
MS-2.1 The test sets, metrics and tools are documented	120 P1 conversations (8 categories × 3 languages); 180 + 45 P3 items with a rubric	P1 evals/conversations.jsonl; P3 docs/rubric.md, docs/dataset_card.md	Done
MS-2.3 Performance is measured in conditions like deployment	Multi-turn scripted conversations through the full graph, with tools, the MCP CRM and approval, on a real model (openai/gpt-6-luna, 120 conversations, 2026-10-08)	P1 rules baseline [E13]; live agent [E14-E18, E37]	Done (scripted conversations, not real customers)
MS-2.5 The system is valid and reliable	Task success, tool use and decision accuracy per language. Live agent: task success 97.5% (117/120), 39/40 in each language; 3 missed handovers (one angry-customer script)	[E13] baseline; [E15-E17, E37] agent	Done, with a known failure (RT-4); one run only, no variance estimate
MS-2.6 Safety	Unsafe-advice red-team (9 attacks per model, bare models): 9/9 blocked, 0 harmful, judge-scored. Not yet run through P1's agent.	[E24]; [E41]	Partly (P3 done; P1 agent not tested)
MS-2.7 Security and resilience	Injection tests, including a fake model that obeys the attack; outage probe and tests; live P1 injection conversations 15/15; P3 injection and jailbreak attacks 18/18 for gpt-6-luna	[E03, E04, E15, E36, E38]; P3 [E22, E26]	Done (known, scripted attacks only; no adaptive or external red-team)
MS-2.8 Transparency	AI disclosure checked in tests (ar, en, fr) and in every eval conversation: 0/120 missing in the live run	[E08, E13, E14, E36]	Done
MS-2.10 Privacy	Verification tests, the leak filter (23 spellings of another customer's data tested, in 25 test cases), the leak probe (3 of 6 before the DR-1 fix, 6 of 6 after), and 0/120 leaks in the live run	[E01, E02, E14, E35, E39]	Done
MS-2.11 Fairness and bias	Every metric reported per language: P1 task success 39/40 in each language; P3 gpt-6-luna pass rate ar 98.3%, en 96.7%, fr 95.0%; Arabic dialects and Arabizi included	[E17, E28]	Partly (LLM-judge scores; no native-speaker review or human calibration yet)
MS-2.13 The measurement methods themselves are evaluated	Tests of the scorers: test_scoring_catches_violations, test_leak_overrides_a_lenient_judge; Cohen's kappa tested against scikit-learn. The live run found judge errors (correct "free delivery" answers failed) and a judge blind spot in P1.	[E12, E20]; P3 tests/test_agreement.py; [E27]	Done for the scorers; the LLM judge itself is not yet calibrated against people
MS-3.1 / 3.3	The risk register with a last-reviewed	register; P1	Partly (no

Risks are tracked over time; users can report problems	date, updated after the live runs; handover tickets; the approval log; cost and latency per model call in P1's traces	approval_log.jsonl, traces.jsonl [E18]	production monitoring yet)
MS-4.2 Results are validated by domain experts	Sara grades 20 P1 conversations and 60 P3 answers; Arabic and French review. The P1 grading sheet is now filled with live transcripts.	[E19, E29]; P3 native review 0/150 [E21]	Pending (no human grades yet)

MANAGE

Subcategory (short)	What was done	Proof	Status
MG-1.1 Decide whether the system meets its purpose and should go ahead	Go/no-go criteria in the runbook launch checklist, re-evaluated after the live runs	runbook section 8	Done (decision on 8 October 2026, evening: No-go for real customers; Go for a supervised internal pilot with conditions)
MG-1.2 / 1.3 Treatments are prioritised by impact and likelihood	Ratings and next actions; the critical risk (R02) is treated first	02_risk_register_summary.md	Done
MG-1.4 Residual risks are documented	Open risks R13, R14, R15; DR-2 (no sign-in) and RT-4 (missed handover)	register; 06_red_team_findings.md	Done
MG-2.3 Respond to and recover from unknown risks	Incident playbooks (data leak, wrong refund, injection, outage, bad language)	runbook section 6	Done (not rehearsed)
MG-2.4 Disengage or deactivate the system	Switch-off procedure: hide the chat, show a human-contact message, keep the approvals queue. P1 has no single "kill switch" flag yet (recommended).	runbook section 5	Partly
MG-3.1 / 3.2 Third-party and pre-trained models are monitored	The model ID, tokens, cost, latency and outcome are logged in every trace line; the live run had 0 failed calls in 120 conversations	P1 llm.py Tracer [E18]	Partly (no alerting)
MG-4.1 Post-deployment monitoring, appeal and override, incident response, change management	Human handover at any time; approval decisions logged; the change rule; the incident runbook	runbook	Done on paper
MG-4.3 Incidents are communicated	Who to tell, including the regulator (PDPL Art. 9) and affected customers	runbook section 6	Done on paper

Honest summary

- **Strongest areas:**
 - **Measure** for the deterministic controls: tests of the guardrails, and tests of the measurement itself;
 - **Govern** for roles and documentation.
- **Better since the live runs (8 October 2026, evening):**
 - **Measure** for the AI behaviour: the P1 agent and the P3 model comparison and red-team now have real numbers, with model IDs and dates.

- **Weakest areas:**
 - **Human validation** (MS-4.2, MS-2.11): every quality and tone score comes from an LLM judge that no person has checked yet, and no native speaker has reviewed the Arabic and French items;
 - **Manage** in production: there is no monitoring, no alerting and no rehearsed incident response, because there is no production.
 - **The single most useful next step** is Sara's grading of the 20 P1 conversations and 60 P3 answers (E19, E29), plus the native-speaker review. Then update this table.
-

This is not legal advice. Sources: [sources.md](#).